ICS 35.240.60
CCS L 07

中华人民共和国国家标准化指导性技术文件

GB/Z 265—2026

“人工智能+交通运输”应用安全指引

Application security guidelines for “artificial intelligence+transportation”

2026-08-27 发布

国家市场监督管理总局
国家标准化管理委员会 发布

目　　次

前言 ……Ⅲ
1　范围 ……1
2　规范性引用文件 ……1
3　术语和定义 ……1
4　总则 ……2
5　生命周期安全要素 ……3
6　应用场景安全风险防范 ……11
附录A(规范性)　交通运输人工智能应用常见安全风险防范 ……12
附录B(资料性)　交通运输典型应用场景突出安全风险防范示例 ……15
参考文献 ……25

前　言

本文件为规范类指导性技术文件。

本文件按照GB/T 1.1—2020《标准化工作导则　第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由交通运输部和中国民用航空局提出。

本文件由全国智能运输系统标准化技术委员会(SAC/TC 268)和全国网络安全标准化技术委员会(SAC/TC 260)共同归口。

本文件起草单位：中国交通通信信息中心、交通运输部公路科学研究所、中国电子技术标准化研究院、交通运输信息安全中心有限公司、中国交通信息科技集团有限公司、青岛港国际股份有限公司、中国远洋海运集团有限公司、中国南方航空集团有限公司、上海机场(集团)有限公司、中国民航信息网络股份有限公司、中国民航大学、华为技术有限公司、交通运输部规划研究院。

本文件主要起草人：杜渐、戴明、陈朴、齐志峰、罗庆勇、何峰、吴宇震、王楹、李飞、吴勇、李金良、耿庆仁、王力、许智宇、张硕、夏威、郝春亮、刘长辉、冯森、张妍婷、陈振东、霍晓宇、孙硕、贺林佳、黄伟键、张卓剑、常鑫宇、曾佩佩。

“人工智能+交通运输”应用安全指引

1 范围

本文件给出了交通运输人工智能应用安全的总则和生命周期安全要素，提供了交通运输人工智能典型应用场景安全风险防范的指导和建议。

本文件适用于交通运输人工智能全生命周期的应用安全工作。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 20839 智能运输系统 通用术语

GB/T 25069 信息安全技术 术语

GB/T 41867 信息技术 人工智能 术语

GB 45438 网络安全技术 人工智能生成合成内容标识方法

3 术语和定义

GB/T 20839、GB/T 25069 和 GB/T 41867 界定的以及下列术语和定义适用于本文件。

3.1

交通运输人工智能应用 transportation artificial intelligence application

人工智能在公路、水路、铁路、民航、邮政、城市客运、综合交通运输等交通运输领域，以及政务服务、业务服务、安全监管等场景中的应用，以实现检索增强、感知认知、推理决策、任务调度等方面的预期结果。

注：包括交通运输基础大模型、交通运输垂直领域大模型、智能体等人工智能应用形式。

3.2

交通运输基础大模型 transportation foundation large scale model

在通用大模型的基础上，基于交通运输行业通识高质量数据集和语料库进行训练的大模型。

注：高质量数据集是经过采集、分析、标注、转换、过滤、标准化、去标识化、质量检查、采样、增强、标记等数据处理，能直接用于开发和训练人工智能模型，有效提升模型性能的数据集合。

3.3

交通运输垂直领域大模型 transportation specific large scale model

在交通运输基础大模型的基础上，基于交通运输领域专识高质量数据集进行训练的大模型。

3.4

智能体 artificial intelligence agent

能够自主感知环境、制定决策、采取行动实现特定目标的智能系统。

注：一般具有记忆、规划、使用工具等基本能力。

3.5

生产开发者　artificial intelligence producer

负责设计、开发、测试和部署由一个或多个人工智能系统所构成的人工智能产品或服务的组织。

注1：生产开发者包括模型算法和应用的生产开发组织，如模型设计方、模型实现方、计算验证方、模型验证方、应用开发方等。

注2：在交通运输行业，生产开发者可能包括模型算法研究机构、大模型和大模型平台厂商、交通运输基础大模型和交通运输垂直领域大模型开发单位和建设单位、智能体生产制造商或开发单位或建设单位、交通运输行业大模型集成商、行业应用单位的研发部门等。

3.6

应用提供者　artificial intelligence application provider

在交通运输行业场景中，将人工智能系统能力（例如推理与决策）以人工智能应用方式作为产品或服务提供给内部或外部业务使用者的组织。

注1：应用提供者可能是生产开发者的外部组织（如大模型平台、智能体开发平台、智能体应用等第三方产品或服务提供者），也可能是生产开发者的内部组织。

注2：在交通运输行业，应用提供者可能包括交通运输基础大模型及大模型平台的运行单位、交通运输垂直领域大模型及大模型平台的运行单位、各类交通运输智能体的运行单位等。

3.7

数据提供者　data provider

为人工智能产品或服务提供数据的组织。

注：在交通运输行业，数据提供者可能包括行业高质量数据集提供者、语料库提供者、行业应用数据提供者、交通运输管理和运营数据提供者，也包括使用过程中需反馈生产、环境、操作等业务数据至模型以支持持续学习与改进的组织。

3.8

业务使用者　artificial intelligence user

最终使用人工智能产品或服务的组织。

注：业务使用者可能与应用提供者之间存在业务关系，例如合作、产品购买或服务订阅；业务使用者可能是应用提供者的一部分，即内部组织，例如业务部门，也可能是合作关系，如第三方服务商、业务客户。

3.9

安全护栏　security guardrails

用于约束和规范人工智能应用行为的一系列策略、机制和技术手段，限制人工智能应用输入输出内容或行为，防止重要数据泄露、提示词注入攻击，以及生成侵犯商业秘密或个人信息、违法和不良信息等。

3.10

车路云一体化系统　vehicle road cloud integration system

通过新一代信息与通信技术将人、车、路、云的物理空间、信息空间融合为一体，基于系统协同感知、决策与控制，实现智能网联汽车及交通系统安全、绿色、舒适及高效运行的信息物理系统。

4　总则

4.1　交通运输人工智能应用遵循包容审慎、风险导向、敏捷治理、技管结合、协同应对、防范失控的安全原则，通过实施基于角色、贯穿全生命周期的安全措施，面向交通运输业务场景人工智能应用的主要风险开展针对性防范，保障人工智能应用安全、可靠、可控。

4.2　交通运输人工智能应用中涉及的角色包括生产开发者、应用提供者、数据提供者、业务使用者。各角色承担相应的应用安全职责，主要包括以下内容。

a） 生产开发者在人工智能系统设计开发、部署过程中保障其模型算法、模型训练、训练数据、计算和模型验证的准确性、合规性、鲁棒性、可解释性等，对人工智能系统承担安全主体责任。

b） 应用提供者在人工智能系统部署、运行和监测的过程中，保障其安全稳定运行和网络数据的完整、保密、可用等，对人工智能系统的运行承担安全主体责任。

c） 数据提供者保障提供的数据来源可靠、准确、多样，对所提供的人工智能系统训练数据的质量承担主体责任；明确数据安全责任主体，并对训练数据的安全收集、存储、使用、加工、传输、提供、公开进行有效监督。

d） 业务使用者在使用人工智能系统之前，审慎评估其安全风险及影响；在使用过程中，保障系统和数据合规使用，并负责对人工智能可控性进行有效监督。

e） 同一单位或组织在作为多个不同角色时，承担各角色相应的安全责任。

4.3 交通运输人工智能应用生命周期通常包括前期规划、设计开发、验证确认、部署、运行监控、持续验证评估、退役下线等阶段。交通运输人工智能系统全生命周期各阶段涉及的相关角色，主要从模型算法、数据、业务应用、信息设施等方面开展人工智能应用安全工作。各阶段需考虑因素的总体框架如图 1 所示。各阶段开展的人工智能应用安全工作主要包括：

a） 前期规划阶段，业务使用者组织对人工智能应用安全进行论证分析；

b） 设计开发阶段，生产开发者、应用提供者、数据提供者、业务使用者规范开展安全管理与安全开发；

c） 验证确认阶段，生产开发者、应用提供者、业务使用者检查人工智能应用及其安全措施是否符合既定需求、实现预期目标；

d） 部署阶段，应用提供者与业务使用者协同保障安全配置；

e） 运行监控阶段，应用提供者保障人工智能系统的持续稳定运行，监控系统运行情况和安全状态，业务使用者保障安全使用；

f） 持续验证评估阶段，生产开发者、应用提供者及业务使用者定期或在关键要素发生变化时，对人工智能系统开展安全验证和评估，必要时退回到设计开发或前期规划阶段；

g） 退役下线阶段，应用提供者建立人工智能应用的安全退出评估、审批通报、处置制度，指定专人负责，严格执行并留存完整记录。

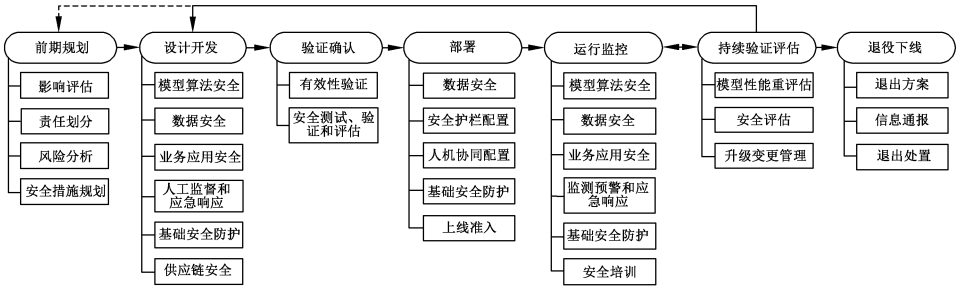


图 1 总体框架

4.4 交通运输人工智能应用场景包括公路、水路、铁路、民航、邮政、城市客运及综合交通运输 7 个领域，贯通基础设施、运输服务、行业治理 3 个业务领域。交通运输人工智能应用场景的安全防护宜基于业务和应用场景特点，以有效防范化解人工智能应用核心安全风险为重点，采取针对性措施。

5 生命周期安全要素

5.1 前期规划

5.1.1 影响评估

业务使用者组织对目标应用场景采用人工智能技术所带来的长期和潜在影响、经济效益、应用范围

进行分析和审慎评估，组织专家评审，形成应用决策。包括但不限于以下方面：

a） 长期和潜在影响：分析应用人工智能（如智慧港口、智慧航道、智慧物流、智慧公路等）对作业模式、行业生态、人员就业等的持续影响；

b） 经济效益：对比传统模式，评估应用人工智能在运营效率、运输效率、成本等方面的优势、投入产出比及风险收益；

c） 应用范围：分析人工智能技术的功能与限制、数据来源与处理方式、决策局限性，结合业务场景确定人工智能应用范围。

5.1.2 责任划分

业务使用者指定人工智能应用安全第一责任人，建立覆盖全生命周期的安全责任机制，明晰各方安全责任与权利。

5.1.3 风险分析

业务使用者组织识别模型算法安全、数据安全、系统网络安全、信息内容安全、现实安全、伦理安全等各类风险及风险等级。包括但不限于以下方面。

a） 模型算法安全风险：重点关注模型泛化能力不足、提示词注入、输出决策不可靠等风险，如在城市轨道交通运力动态匹配、内河客运船次智能调度等场景中，存在模型被诱导生成错误调度指令的风险，可能导致交通秩序混乱、车辆或船舶碰撞等事故。

b） 数据安全风险：参考GB/T 43697、JT/T 1522、GB/T 35273和GB/T 45574，重点识别训练和应用过程中存在的敏感信息泄露、违规数据收集等风险。如在交通运输政务问答场景中，检索增强生成（RAG）知识库数据中可能存在敏感政策文件泄露风险；在交通运输基础设施勘察报告智能生成场景中，可能存在路桥隧、港口、航道等基础设施的高精准参数等敏感数据泄露风险；在驾驶员状态智能监测研判场景中，可能存在个人敏感数据违规收集风险。

c） 系统网络安全风险：重点分析交通运输基础大模型、交通运输垂直领域大模型、智能体等在组件算力、网络拓扑、内外部通信、系统策略、权限控制、资源调用、流程编排等方面存在的安全漏洞、网络暴露面扩大、可靠性不足、供应链安全等风险，如在涉及多式联运的场景中，可能存在权限控制细粒度不足和流程编排存在漏洞等风险。

d） 信息内容安全风险：参考GB/T 45654—2025中附录A识别训练数据、输入内容及生成内容是否包含违反社会主义核心价值观、歧视性、侵犯他人合法权益等高风险内容，尤其是涉及生成式人工智能服务的应用场景（如智能问答等）。

e） 现实安全风险：重点识别因错误决策、不当使用、外部攻击等可能引发的系统性能下降、服务中断、操作执行失控等问题，导致交通运输领域关键信息基础设施安全稳定运行风险加剧，进而造成经济社会运行安全风险。

f） 伦理安全风险：遵循科技伦理规范，识别伦理安全风险，必要时可采用伦理审查方式，如在智能辅助驾驶场景中，存在因技术可靠性不足导致事故问责困难、道德决策偏见及隐私侵犯等风险。

g） 自动化决策安全风险：涉及基于个人信息的自动化决策的应用场景（如智能导航、旅客出行路线规划等），参考GB/T 45392—2025中4.4评估识别自动化决策安全风险。

h） 跨境应用安全风险：涉及跨境应用的场景（如智能船舶驾驶、船岸云协同、国际快件分拣、远洋航运智能规划等），分析因数据出境、境外法律适用等带来的法律、运营和声誉风险，评估跨境合规风险，如对国际海事组织（IMO）、国际船级社协会（IACS）等发布的网络和数据安全、人工智能安全等要求的合规。

5.1.4 安全措施规划

业务使用者组织开展安全措施规划，主要包括以下方面：

a) 结合安全风险识别情况，参考国家和行业网络安全等级保护、数据安全、密码应用等标准内容，组织生产开发者、应用提供者开展网络安全等级保护定级，同步规划人工智能系统的网络安全、数据安全、密码应用安全措施，以及系统冗余架构和容灾机制；

b) 规划决策校验与纠偏机制、人工介入措施和人机协同体系，包括一键接管、版本回退、紧急关停、人工复核等措施，确保人类具备最终控制权限。

5.2 设计开发

5.2.1 模型算法安全

生产开发者、应用提供者对模型算法进行安全防护，主要包括以下方面：

a) 构建有效可靠的对齐算法；选择可解释性强、隐私与安全保护完善、符合科技伦理及交通行业价值观规范、模型指标（生成内容合格率等）符合业务需求的基础模型（如交通运输基础大模型、交通运输垂直领域大模型等），开展基础模型、开源模型安全缺陷传导评估，并设计实现预防缓解措施。

b) 设计实现对人机交互接口和应用程序编程接口（API）的用户身份识别及权限控制，根据业务场景限制接口调用频率和用户高风险操作，建立恶意行为阻断机制。

c) 对模型开展对抗性训练，并制定输入验证规则（格式/内容/来源），对读取的外部内容（如识别的运单内容、外部知识库等）与用户指令通道进行隔离，如采取沙箱、上下文隔离等技术，防止将外部数据误判为系统指令。

d) 应采用符合GB 45438的显式标识和隐式标识对生成合成内容进行标识；建立内容安全风险预警、动态过滤机制，构建场景化提示词模板与输出约束。

e) 提供决策依据与置信度说明，制定重大影响决策解释预案（如港口调度延误、危险品误判等场景）。

5.2.2 数据安全

生产开发者、应用提供者、数据提供者对数据进行安全防护，主要包括以下方面。

a) 采用真实准确、来源合法可靠、可追溯、多样化的训练数据，与验证数据、测试数据间相互独立；开展数据来源检测校验和合规性审查，保障训练数据来源合规可靠、可追溯。

b) 参考GB/T 45654规范训练数据安全防护，参考GB/T 45674规范训练数据标注安全，参考GB/T 45652规范预训练与优化训练数据安全。

c) 定期抽检训练数据质量，开展对训练数据的投毒检测和偏见歧视检测等安全性检测。

d) 隔离训练环境（如私有化平台），采用物理隔离或逻辑隔离方式阻断外部网络访问，避免数据泄露、不当访问等安全事件，保障训练环境安全。

e) 采用数据脱敏、联邦学习、差分隐私等技术加强用户和系统等运行数据的安全防护及隐私保护，对生物特征等敏感数据实施加密存储与访问控制；对RAG知识库等数据进行周期性的完整性、一致性校验，防止数据被恶意篡改。

5.2.3 业务应用安全

生产开发者、应用提供者对业务应用进行安全防护，主要包括以下方面：

a) 依据人工智能应用范围，裁剪易被滥用的功能，在架构、数据流、性能和可用性等设计中考虑安

全适用的部署方式(如云端、边缘端、端侧部署等)及应用监控组件;

b) 设计实现智能体身份标识、数据及业务细粒度权限访问控制,采取安全验证与严格准入、双向身份认证和加密等措施,防范模型上下文协议(MCP)、智能体通信协议(A2A)等协议安全风险;

c) 设计实现人工智能系统访问各类业务资源(如数据、文件、接口、工具等)的频率阈值管控、行为监测和阻断机制,如限制信号灯修改等控制执行类API调用频率、监控多智能体的异常行为或资源抢占消耗等情况、阻断异常调度指令和决策等。

5.2.4 人工监督和应急响应

生产开发者、应用提供者设计实现人工监督机制和应急响应措施,提供设置人工复核节点、及时切换到人工或传统系统等功能,构建完善的人机协同体系,主要包括以下方面:

a) 根据人工智能安全风险等级,建立分级监督模式,按风险等级设计实时批准、事后审查及异常干预机制;

b) 具备一键关停能力,关键信息基础设施宜实现人工智能系统与传统系统的安全快速切换。

5.2.5 基础安全防护

生产开发者、应用提供者、数据提供者按照网络安全等级保护、数据安全、密码应用等相关要求构建基础安全防护体系。

5.2.6 供应链安全

生产开发者、应用提供者、数据提供者、业务使用者对硬件、芯片、软件、工具、算力及数据资源等的供应链安全实施管理,主要包括以下方面。

a) 开展供应链安全评估,确保其持续稳定与安全可靠,优先采用已备案或通过国家网络安全认证的产品。

b) 参考GB/T 43698,生产开发者向应用提供者和业务使用者提供完整系统物料清单,含训练数据集、基础模型、依赖库(包括开源组件的协议和版本等信息)等,保障模型、算法等全链路可追溯。

c) 定期对开发框架、组件及代码进行安全审计,不使用存在已知安全风险的组件;实施常态化漏洞扫描,修复安全漏洞。

d) 选用成熟稳定版本的模型文件、框架工具及第三方库;通过官方渠道获取资源,采用数字签名验证完整性与真实性,并进行必要的安全测试,防范后门攻击。

5.3 验证确认

5.3.1 有效性验证

生产开发者、应用提供者、业务使用者在应用场景中对人工智能应用决策开展有效性验证,主要包括以下方面:

a) 对决策指令等设置有效性评分规则并进行评价,如在梯级船闸联合调度场景中,从作业耗时、资源利用率等维度对人工智能决策进行评分,通过性能测试对响应时间、资源利用率等进行测试,判断是否符合业务场景要求;

b) 对人工智能决策结果的有效性进行验证,如在智能辅助驾驶、交通流量预测研判、铁路客运列车智能调度等场景中,模拟恶劣天气、车辆人员密集等条件,对人工智能应用产生的调度指令等进行测试,判断是否能有效避免碰撞、提升通行效率;

c) 必要时开展人工比对,如对通过高分辨率摄像头、激光雷达等采集的真实道路或模拟环境中的

视频流和数据流，由标注员框出车辆、行人、交通标志等目标，对比验证模型识别目标的平均精度、漏检率、误检率，判断其是否达到对周围环境精准感知的目标；

d） 对输出内容预检测或使用其他大模型等自动化手段进行交叉验证，防止因幻觉等导致输出错误，确保系统输出符合行业规范，如危险品识别、政策解读等场景，避免出现将普通货物误判为危险品导致物流延误、对高速公路收费政策解释错误、航运不符合商业伦理或国际海事惯例等情况。

5.3.2 安全测试、验证和评估

生产开发者、应用提供者加强对人工智能系统的安全测试、验证和评估、应急管控验证，尤其是涉及可能影响交通运输关键业务运行、设备设施安全、人身安全等的控制、决策类人工智能系统，主要包括以下方面。

a） 参考GB/T 42888、GB/T 45652和GB/T 45654，对人工智能系统训练数据和算法、模型进行安全性评估。

b） 对人工智能系统透明度和可解释性进行评估和验证，重点对鲁棒性、可靠性、韧性、可控性、可预测性、适用性、决策逻辑等的说明文档内容进行验证，对公平性与偏见、价值观对齐等进行测试。

c） 对人工智能系统在面临故障、攻击等异常情况下的弹性能力进行评估测试，评估系统对外界干扰的容忍程度，如开展补充故障示例、提示词注入攻击、模型反演攻击、系统滥用与越狱攻击、指令忽略、资源滥用与拒绝服务、输出一致性和稳定性等测试。

d） 对安全护栏开展模拟绕过、欺骗或破坏护栏等对抗攻击测试，主要包括：

1） 对误差容忍机制、人工预警机制、人工监督机制和人机协同体系、一键接管和紧急关闭等应急切换能力进行验证，如智能辅助驾驶、车路云一体化系统、智能船舶、船岸云一体化系统、无人机智能配送等对物理世界强感知依赖的应用场景，在投入使用前对感知系统进行大面积遮挡、强电磁干扰等极端条件测试；

2） 对软硬件设备、第三方工具、第三方服务接口进行API鉴权、输入验证等安全测试，对人工智能应用的交互界面、API、数据库、服务器等进行渗透测试，修复可被利用的已知漏洞。

5.4 部署

5.4.1 数据安全

应用提供者与业务使用者遵循最小化数据访问原则配置数据权限，按功能模块设置数据访问边界，如货运调度系统仅访问装卸时间窗、车辆载重等业务数据，车路协同系统仅调取路况实时数据（车流密度、信号灯状态），邮件快件识别系统仅处理条码与地区信息，避免敏感信息泄露。

5.4.2 安全护栏配置

应用提供者对安全护栏配置风险防控策略，设置业务场景专用提示词与输出格式，通过实时监测和预警机制，动态识别与约束不符合规范的系统行为与输入输出内容。

5.4.3 人机协同配置

应用提供者根据业务特点和业务使用者需求合理设置人机协同配置，主要包括以下方面：

a） 在关键决策节点设置人工复核，如工业控制系统（ICS）指令需二次确认；

b） 启用双轨切换机制，定义触发条件，设置自动切换预警阈值和手动切换权限。

5.4.4 基础安全防护

应用提供者加强信息设施安全防护，主要包括以下方面。

a) 通过官方渠道获取模型文件、框架工具及第三方库，验证资源的完整性（如数字签名校验）与真实性；对部署软硬件进行安全检测，确保无已知漏洞。

b) 准确配置运行环境参数、功能模块调用策略，关闭非必要的网络端口和功能服务，开启日志记录与审计。

c) 建立智能体等人工智能应用系统管理清单，对系统身份标识、状态、功能、可执行操作或行为权限、可访问数据、安全责任人等进行统一管理。

d) 对模型、知识库、外部工具等的升级、更新、删除等执行权限进行严格控制，最小化操作执行权限，并设置操作日志记录。

e) 人工智能系统与整体安全防护架构相融合，与防火墙、入侵检测等设施联动，将训练环境与推理环境隔离。

f) 参考GB/T 39786相应级别要求对传输和存储的数据及模型文件进行加密保护，如基础环境配置数据、运行日志数据、应用与模型交互时的用户和业务数据、模型输入输出、跨模块通信等。

g) 设置必要的冗余备份和灾难恢复配置。

h) 涉及云部署的，应用提供者根据人工智能系统的网络安全保护等级，选择云服务提供商，采用数据和通信加密、计算隔离、存储隔离和严格的权限管理等措施提升防护能力；涉及模型在端侧部署的，应用提供者参考GB/T 45654—2025中6.7进行安全防护。

5.4.5 上线准入

应用提供者、业务使用者建立上线准入机制，上线前对模型算法、训练和应用数据进行安全评估，对信息设施、应用功能、生成内容进行集成测试、安全测试和评估。

5.5 运行监控

5.5.1 模型算法安全

应用提供者通过对模型的运行监测、可信性校验及对抗性检测等安全防护机制，保障模型安全，防止模型在运行过程中遭受干扰、篡改或数据污染。

5.5.2 数据安全

应用提供者在系统运行过程中保障数据安全，业务使用者在使用过程中保障自身输入数据的安全，主要包括以下方面。

a) 应用提供者建立人工智能系统对数据的访问控制和监控机制，制定权限申请、审批、变更全流程规范，定期检查和审计数据访问和操作记录，动态调整权限，实现权限调整可追溯、可审计。

b) 涉及运行过程中收集数据用于持续训练学习的，生产开发者、应用提供者、数据提供者通过制定数据留存、销毁、清洗等规则并定期更新；记录数据处理全过程，建立数据质量监测机制等措施保障训练数据安全可靠，建立数据溯源和回滚机制；如在政务信息公开、监管取证等场景中，可利用深度伪造检测工具对疑似大模型生成的信息实施来源核验与交叉验证。

c) 业务使用者增强数据和个人信息保护意识，不违规向智能体等人工智能系统输入敏感数据，交通运输行业敏感数据参考JT/T 1522进行识别。

d) 业务使用者明确数据收集的范围与内容、数据的使用方式、数据安全或数据治理策略，对收集的数据（如反馈至模型以支持持续学习与改进的数据）进行分析和保护。

5.5.3 业务应用安全

应用提供者、业务使用者在系统运行过程中保障业务应用安全，主要包括以下方面：

a) 应用提供者记录人工智能系统运行日志，日志留存时间不少于6个月，并定期开展审计，其中互联网政务应用系统日志留存时间不少于1年；

注：系统运行日志包括系统行为、用户行为日志，如所有输入接口调用、用户输入、输出操作内容、生成参数与审核记录、用户和系统的数据访问与外部交互记录、工具调用链、资源消耗记录等。

b) 应用提供者、业务使用者建立人工智能决策及行为抽查机制，如定期抽取决策记录和行为日志，核查是否存在不合理决策或异常行为；

c) 业务使用者在使用过程中对人工智能行为和影响、人工智能可控性、系统审计和安全审计进行定期检查，以进行有效监督；

d) 应用提供者采用安全护栏等手段对内容安全和行为安全进行管理，同时保障护栏运行安全，主要包括以下方面：

1) 制定清晰的人工智能安全策略，规定安全护栏机制的目标、适用范围、最低要求和管理责任；

2) 对人工智能系统的输入和输出进行过滤；

3) 对人工智能系统行为进行监控，发生异常时能够紧急阻断；

4) 保障安全护栏持续有效运行，实时监控安全护栏运行状态及异常告警，定期对安全护栏日志进行审计，检查其防护有效性，识别模型的潜在漏洞和滥用风险。

5.5.4 监测预警和应急响应

应用提供者、业务使用者建立监测预警和应急响应制度并严格执行，主要开展以下方面。

a) 建立人工智能系统实时监测与风险预警机制，对智能体等人工智能系统的输入输出、操作、行为等进行异常监测和告警；涉及生成式人工智能服务的，参考GB/T 45654—2025中5.3和6.4开展模型监测工作，接受公众或业务使用者的投诉举报。

b) 建立人工智能系统运行安全事故、安全漏洞报告机制，定期跟踪漏洞情况。

c) 定期检查人工补偿措施的合理性和有效性，保障人工监督机制有效运行。

d) 将人工智能系统相关的威胁情报纳入网络安全情报获取和共享范围，并进行闭环管理。

e) 制定专项应急预案，针对有害或违规内容、模型失控、模型误判、数据篡改、数据投毒、提示词注入、安全护栏机制失效或被绕过等场景，预案内容包括故障分级、处置流程、处置措施及责任分工等，设置事故应急报告与处置机制、事故信息回溯机制。

f) 定期开展安全演练并留存记录，尤其是人工干预措施演练，结合行业安全事件、重要舆情及监管变化，及时优化应急策略。

5.5.5 基础安全防护

应用提供者强化信息设施安全防护能力，确保人工智能系统产生的网络流量、数据交互行为全程在整体防护策略的防护范围内，主要开展以下方面。

a) 同步运行人工智能系统的网络安全等级保护、数据安全、密码应用等基础安全防护措施。

b) 对跨域数据进行必要的脱敏处理和严格的细粒度数据权限控制。

c) 定期检查系统配置、运行环境参数、功能模块调用、访问速率限制策略，关闭非必要的网络端口和功能服务，重点检查默认配置、默认口令，及时消除安全风险。

d) 建立漏洞追溯机制，对第三方大模型、API、云平台等外部依赖服务进行持续跟踪，定期开展安全检测，及时处置安全风险隐患。

e） 加强对人工智能应用账号的访问权限管理和数据隔离，增强账户安全性，对异常和恶意账户及时检查清理。

f） 建立数据、模型、框架、工具等的备份恢复策略，重点保障业务连续性；制定人工智能应用服务和数据的备份恢复计划，包括备份对象、备份频率、不同故障场景下的恢复流程等。

g） 对聚合多个人工智能模型或系统的平台（如外部第三方平台），加强身份认证、权限管理、传输安全和数据安全措施，完善人工智能应用服务接口的授权和访问控制策略，防止针对某个模型或系统的恶意行为和攻击入侵影响其他人工智能模型或系统。

5.5.6 安全培训

应用提供者、业务使用者定期组织安全培训，提升人员人工智能安全操作能力，主要包括以下方面：

a） 加强人工智能安全素养和安全使用技能培训，涵盖大模型理论、人工智能技术、智能体应用、人工智能安全、伦理风险等内容，提升使用人员对人工智能安全的认知水平，增强使用人员对人工智能的安全应用能力，建立科学理性认识，设置合理应用预期，依法合规使用；

b） 应用提供者对人工监督等岗位人员进行专项培训，增强对人工智能系统的能力边界、典型失效模式和应急处置流程等的理解。

5.6 持续验证评估

5.6.1 模型性能重评估

应用提供者对模型性能开展重评估与更新，主要包括以下方面：

a） 建立模型性能持续监测机制，定期评估由于数据分布变化（如交通流量、货物类型、用户行为等）对模型性能产生的影响；

b） 当监测到模型性能下降、发生概念漂移或影响业务生产效率时，及时对模型进行再训练或更新。

5.6.2 安全评估

应用提供者、业务使用者定期开展安全评估，主要包括以下方面。

a） 应用提供者开展周期性安全评估，定期开展网络安全等级保护测评、密码应用安全性评估、数据安全风险评估、个人信息保护合规审计及渗透测试等工作，重点评估以下方面：

1） 人工智能系统的决策有效性、合规性与伦理风险防范；

2） 训练数据及算法模型的安全性；

3） 输入验证与输出阻断机制的有效性；

4） 安全护栏机制在对抗攻击下的防御能力等。

b） 业务使用者定期评估人工智能应用的可信度、透明性及可解释性，并将发现的应用安全风险、伦理风险或改进建议及时反馈给应用提供者。

5.6.3 升级变更管理

生产开发者、应用提供者在监管或业务需求、依托算法或技术发生变化，出现内容安全事故、发现模型或其相关组件存在漏洞等情况时进行模型的更新迭代，对升级变更进行管理，考虑以下方面。

a） 在实施系统升级或模型变更前，评估其对现有业务连续性及关联系统的影响。

b） 实施变更时，对运行环境、服务、版本及数据进行完整备份，确保具备回滚能力；采用安全的模型分发和版本控制方式，保障分发过程中模型等更新文件不被篡改。

c） 涉及机器学习算法的，参考GB/T 42888—2023中5.1.5进行维护升级；涉及生成式人工智能服务的，参考GB/T 45654—2025中5.4保障更新安全。

d） 生产开发者定期披露算法审计、异常处置和漏洞修补情况，指导支持应用提供者、业务使用者采取防范措施，当人工智能系统存在较大功能局限或安全风险时，及时更新情况说明，明确适用范围、使用禁忌和处置措施；应用提供者据此及时采取措施进行漏洞验证、修补和系统加固。

5.7 退役下线

5.7.1 退出方案

在人工智能应用过时、出现重大问题无法修复或业务发生变化时，应用提供者组织生产开发者、业务使用者评估终止人工智能系统的必要性、可行性、影响和风险，形成完整的安全退出方案，主要包括：

a） 评估对业务、最终用户等的影响；
b） 分析与模型、数据及其他集成系统之间的依赖关系以确定影响范围；
c） 分析数据泄露、业务连续性等方面的安全风险并提出应对或缓解措施；
d） 建立数据和设备资产处置清单；
e） 制定退出时间和处理计划等。

5.7.2 信息通报

审批确认退出后，应用提供者及时将退出决策和方案通报业务使用者、监管机构等。

5.7.3 退出处置

应用提供者实施数据删除、资产和介质回收或销毁，重点针对模型文件、训练数据、训练脚本、参数配置、服务配置、用户数据、业务数据等数据进行安全处置并记录操作日志；机器学习算法的退役下线，参考GB/T 42888—2023 中 5.1.6 开展。

6 应用场景安全风险防范

交通运输人工智能应用场景基于业务和应用场景特点，可能面临不同的安全风险，宜根据附录 A 中的风险分析和常见安全风险防范，采取相应措施有效防范化解安全风险，以提高人工智能应用安全防护能力。

本文件从基础设施、运输服务、行业治理 3 个领域，选取公路、水路、民航、邮政、城市客运、综合交通运输等领域中影响范围广、应用程度深、应用效果显著的典型人工智能应用场景作为示例，梳理各场景可能面临的突出风险，在第 5 章和附录 A 的基础上，提出相应防范措施。交通运输各典型应用场景突出安全风险防范示例见附录 B。

附 录 A
（规范性）
交通运输人工智能应用常见安全风险防范

A.1 交通运输业务领域应用场景风险分析

交通运输业务领域应用场景划分及主要安全风险如下。

a） 基础设施服务管理业务领域，围绕全生命周期智能化、风险防控前瞻化、资源调配科学化，包括规划建设类、养护类、运营类。主要安全风险包括敏感信息泄露、数据投毒、输出决策不可靠、系统提示泄露、供应链风险、无限资源消耗等。

b） 运输服务业务领域场景围绕资源调度智能化、服务响应精准化、跨域协同高效化，包括出行服务类、货运物流类。主要安全风险包括敏感信息泄露、提示词注入、身份与权限滥用、输出决策不可靠、不当输出、系统提示泄露、供应链风险、无限资源消耗等。

c） 行业治理业务领域场景围绕流程效率提升、决策质量优化、管理模式转型，包括行政办公类、应急管理类、行业监管类场景。主要安全风险包括敏感信息泄露、数据投毒、提示词注入、过度授权、身份与权限滥用、输出决策不可靠、不当输出、系统提示泄露、供应链风险等。

A.2 交通运输人工智能应用常见安全风险防范措施

交通运输人工智能应用常见安全风险防范措施见表A.1。根据应用场景所在领域，参考表A.1分析主要风险和策略建议，分析识别安全风险，并在各生命周期阶段采取对应防范和缓解策略。

表 A.1 交通运输人工智能应用常见安全风险防范措施

序号	常见安全风险项	风险描述	风险示例	防范和缓解策略建议
1	提示词注入	通过直接或间接输入篡改人工智能系统行为，可能使其违反指南、生成有害内容、启用未经授权的访问/操作、影响关键决策，如导致智能体目标劫持、智能体失控等	a） 直接提示词注入； b） 间接提示词注入； c） 代码注入； d） 负载分割； e） 多模态注入； f） 对抗性后缀； g） 多语言/混淆攻击； h） 恶意样本注入	a） 约束模型行为； b） 定义和验证预期输出格式； c） 输入输出过滤及多层级数据验证； d） 最小权限访问； e） 人工审批高危动作； f） 隔离外部内容； g） 对抗性测试和模拟攻击
2	敏感信息泄露	训练数据（预训练/微调数据等）、知识库数据、生产运行数据中存在未经过滤的敏感信息，可能通过人工智能输出暴露专有算法、个人隐私信息、敏感政务信息或业务数据、非公开内部信息等敏感数据	a） 权限细粒度不足； b） 远程代码执行攻击； c） 智能体持久化内存、RAG存储、会话上下文等被篡改； d） 智能体间、跨域通信不安全； e） 向量与嵌入漏洞	a） 数据清洗与输入验证； b） 严格访问控制与数据源限制； c） 联邦学习/差分隐私/同态加密等隐私计算技术； d） 数据脱敏； e） 安全使用培训； f） 数据使用透明度； g） 安全通信协议与安全配置

表 A.1　交通运输人工智能应用常见安全风险防范措施（续）

序号	常见安全风险项	风险描述	风险示例	防范和缓解策略建议
3	数据投毒	在预训练、微调或嵌入数据阶段通过操控数据引入漏洞、后门或偏见	a）训练数据存在有害数据； b）训练过程注入恶意内容； c）无意注入敏感或专有信息； d）未验证的训练数据； e）资源访问限制不足； f）训练数据鲁棒性不强； g）跨上下文信息泄露与联邦知识冲突； h）篡改智能体持久化内存、RAG存储、会话上下文等； i）嵌入反演攻击	a）数据合法性及数据来源质量验证； b）数据集版本控制； c）对抗攻击测试； d）RAG和归因技术应用； e）高噪声容忍度方案； f）内存写入前的恶意内容扫描； g）隔离用户/域的内存上下文； h）未验证内存定期过期，支持回滚/隔离； i）知识库源文件和嵌入向量库校验； j）数据分类审查； k）数据权限与访问控制； l）监控日志记录
4	信息输出决策不可靠	由幻觉生成看似准确但实际上虚构的内容；训练数据中信息不完整或存在偏差等，造成信息输出决策不可靠风险	a）生成看似合理的错误内容； b）事实性误导； c）无依据的主张； d）专业能力的错误呈现； e）不安全的代码生成； f）错误或偏见决策生成	a）RAG技术应用； b）模型微调； c）交叉验证； d）人工智能生成合成内容标识； e）安全使用培训； f）知识库溯源与引用强制机制建立
5	不当输出	在将人工智能模型生成的输出传递给其他组件和系统之前，未进行验证、清理或处理，导致越权访问或远程执行；输出违规内容	a）远程代码执行； b）浏览器中的跨站脚本和跨站请求伪造； c）结构化查询语言（SQL）注入； d）后端系统的服务器端请求伪造； e）路径遍历漏洞； f）钓鱼攻击； g）包含违反社会主义核心价值观、歧视性、商业违法违规、侵犯他人合法权益等违规内容	a）人工智能输入验证和清理； b）人工智能输出的多重验证和安全编码； c）数据库操作使用参数化查询或预处理； d）严格的内容安全策略； e）输出监控和日志记录； f）速率限制； g）异常检测

表 A.1　交通运输人工智能应用常见安全风险防范措施（续）

序号	常见安全风险项	风险描述	风险示例	防范和缓解策略建议
6	过度授权	模型服务或智能体功能、数据权限、执行权限不当，以及人工智能模块的异常行为、模糊输出或恶意操控，导致系统执行破坏性操作或对合法工具进行非预期/不安全使用	a）功能过多； b）权限过高； c）自主性过强； d）跨插件请求伪造等恶意输出	a）功能裁剪与限制； b）最小化扩展权限； c）最小化扩展调用或工具； d）工具调用在沙箱中执行并做出口控制； e）高风险操作人工审批； f）清理输入输出； g）全面日志监控与漂移检测
7	身份与权限滥用	利用系统用户对人工智能的信任，以及智能体间的信任、委托链、权限继承等，导致非授权执行、权限提升、绕过控制、数据泄露或系统控制被篡改等	a）无范围的权限继承； b）基于记忆的权限保留与数据泄露； c）跨代理信任利用； d）工作流中的资源状态安全问题； e）合成身份注入	a）任务限定时间、绑定权限； b）隔离智能体身份和会话上下文； c）每步特权操作重新验证授权； d）高风险操作多步人工确认； e）检测委托与传递权限、异常提权行为； f）为人工智能建议添加可信度标识和来源溯源； g）日志记录与溯源
8	系统提示泄露	模型服务或智能体内部功能、规则、过滤条件、角色权限等重要配置暴露，为各类攻击提供信息。	a）敏感功能暴露； b）内部规则暴露； c）过滤条件暴露； d）权限与角色结构暴露	a）系统敏感数据分离； b）严格行为控制； c）外部独立防护措施，确定性、可审计的权限控制措施
9	供应链	人工智能系统开发、部署全流程依赖的第三方组件、模型、数据存在漏洞，攻击面覆盖全供应链，尤其是第三方提供的智能体、工具、模型等组件在传输、使用中被篡改或植入恶意内容，含运行时动态加载组件风险	a）传统第三方组件漏洞； b）许可风险； c）过时或已弃用模型； d）脆弱的预训练模型； e）弱模型溯源； f）利用协作开发流程； g）设备端模型供应链风险； h）模糊条款与数据隐私政策	a）建立供应链软件物料清单（SBOM）； b）组件漏洞扫描； c）许可证审计； d）使用可验证来源模型； e）对供应模型和数据进行安全测评； f）加密端侧模型
10	无限资源消耗	基于输入查询或提示生成输出过程中出现的资源滥用风险	a）可变长度输入泛滥； b）针对人工智能服务按量收费模式的钱包拒绝服务攻击； c）持续输入溢出； d）资源密集型查询； e）API模型提取； f）功能模型复制； g）侧信道攻击	a）输入验证； b）速率限制； c）资源分配管理； d）访问控制； e）模型算法水印； f）超时与节流； g）异常检测

附 录 B
（资料性）
交通运输典型应用场景突出安全风险防范示例

B.1 基础设施——运营：车路云协同感知

B.1.1 场景描述

在车路云一体化系统应用中，实时整合自动驾驶出租车等车端、路侧与云端感知数据，精准识别道路环境、交通事件与车辆状态；云端汇聚道路基础设施、路网运行状态、道路气象环境、道路交通事件等多维海量数据，利用大数据分析、机器学习和交通流理论模型，进行宏、中、微多层级的交通状态预测、交通流量诱导、信号灯配时优化、交通协调控制、动态车道管理、公交优先通行、危险货物运输路径规划和风险预警等。车端使用人工智能算法处理来自摄像头、多种雷达等车辆传感器、路侧单元、其他车辆的车辆与车外其他设备之间无线通信（V2X）设备的融合数据，实现更精准的超视距环境感知和驾驶员状态监测，支持盲区预警、路径规划，以及变道、跟车、紧急避障等决策控制，以及如重载货车等大型车辆的疲劳驾驶识别与干预。

B.1.2 风险分析

本场景宜重点考虑以下风险：

a） 数据投毒：通过伪造流量等方式进行数据投毒，污染云端训练数据，导致交通控制策略失效；

b） 无限资源消耗：网络暴露面扩大，如云端中心遭受分布式拒绝服务攻击、高级持续性威胁等网络攻击，导致系统瘫痪，造成区域交通失控；

c） 提示词注入攻击：干扰摄像头/雷达等的对抗注入攻击导致车端人工智能误判环境的感知欺骗；通过数据篡改伪造车辆状态或路侧信息，如虚假拥堵信号等，诱导危险行为；

d） 敏感数据泄露：大量出行信息及分析预测，涉及行踪轨迹、车辆状态、驾驶员信息、货运信息、道路状态等，存在数据泄露风险。

B.1.3 防范措施

针对上述风险，宜采取以下防范措施。

a） 生产开发者、应用提供者在设计开发阶段、部署阶段、运行监控阶段采用数据源设备身份认证、异常行为检测等安全管控措施保障数据源设备安全可信，采用数据源认证、数据签名、数据加密等措施对数据传输存储进行安全保护，防止数据伪造，避免数据投毒。

b） 生产开发者、应用提供者在设计开发阶段和部署阶段建立健全网络安全防范措施，部署抗分布式拒绝服务攻击等网络安全防护设备及措施，同时云端采用负载均衡技术及分布式架构，部署边缘计算节点，实现本地化决策备份，强化云端弹性。

c） 生产开发者、应用提供者在设计开发阶段和部署阶段对路侧设备，采用固件安全启动和可信密码模块（TCM），实现基于证书认证的身份认证，同时采用定期证书轮换配合入侵检测系统保障设备安全可信；同时对路侧设备发送的感知信息进行数据签名和端对端加密，实现数据完整性、保密性保护；对于其他V2X车辆，同样采用TCM实现基于证书认证的身份认证、数据签名和端对端加密，保障V2X车辆身份可信和信息交互安全可信；对关键设备加强物理防护，采用网格化部署和设备故障自动告警设置。

d） 生产开发者、应用提供者在设计开发阶段采用如多传感器融合和对抗训练结合等方式增强模型鲁棒性，在路侧设备提供冗余感知验证，强化数据安全防护措施，同时建设实时监控系统，提供异常时触发人工接管或安全模式的能力；在验证确认阶段对严格极端场景、边界案例进行测试。

e） 应用提供者在运行监控阶段建立多模态语义一致性校验机制，当不同传感器（视觉、雷达、气象数据）对同一环境状态的感知结果出现逻辑矛盾时，系统自动降级为“安全故障”状态，不再进行人工智能融合推理。

f） 针对多智能体协同场景，生产开发者、应用提供者在设计开发阶段和部署阶段设计实现隔离机制，确保不同智能体在同一网络中交互时，错误决策不会在整个网络中广播蔓延。

g） 应用提供者在运行监控阶段保障车端、路侧和云端运行期间的数据安全，并采取数据容灾备份措施；提供导航电子地图服务的，参考GB 20263进行空间位置和内容的安全处理。

B.2 基础设施——运营：民航机务维修

B.2.1 场景描述

在民航维修保障中，人工智能已应用于飞机绕机检查、定检维修以及航电系统深度维修等环节。在绕机检查中，人工智能用于辅助识别外观损伤、液体渗漏和轮胎磨耗等异常，有助于提高检查的完整性和一致性。在定检与航线维修中，人工智能通过分析飞行数据和系统运行数据，能够识别关键部件可能的性能下降趋势，为制定计划性维护安排提供支持，从而减少突发性故障的发生；在深度维修和部件级诊断中，人工智能也用于辅助定位电路板及系统级故障位置，缩短排障时间，提高维修效率。

B.2.2 风险分析

本场景宜重点考虑以下风险：

a） 数据投毒：人工智能的识别结果依赖模型质量和运行数据，当模型训练不充分或输入数据受到干扰、缺失、被篡改时，可能产生误判、漏判等不可靠输出，存在误导维修决策的风险；

b） 信息输出决策不可靠：人工智能模型在不同季节、地区、载荷和航线条件下的适应性存在差异，若模型训练和验证未充分覆盖相关工况，可能出现性能波动、过度自信判断或人工智能幻觉现象，影响故障识别准确性；

c） 不当输出：在缺乏明确使用边界和人工复核机制的情况下，系统过度依赖智能模型可能导致人员经验弱化；当模型更新不规范或系统出现异常时，可能影响维修保障能力和放行安全，存在运行安全隐患。

B.2.3 防范措施

针对上述风险，宜采取以下防范措施。

a） 业务使用者按照“人工智能提示、人工分析、最终放行”的流程，定检前完成工况回放与稳定性验证，并将相关记录纳入受控技术文件，在手册中注明人工智能结果的适用范围，并将其自动降级为参考信息。依据CCAR-145R4对技术文件受控、记录完整、安全管理体系以及维修放行签署的硬性要求，将人工智能输出归入受控技术资料，由授权人员承担最终责任。

b） 应用提供者通过数据来源白名单、完整性校验、篡改审计等措施保障数据安全，对关键数据实行签名留痕，并在训练/推理前执行剔噪与异常检测，当异常触发时，系统进入只读状态并启动人工复核；参考GB/T 45654对数据合法来源、访问控制、审计追踪提出的要求，将上述措施纳入运行规范，并与CCAR-145R4的文件控制与可追溯性要求相衔接，确保记录一致且可核验。

c） 应用提供者在部署阶段配置多模型或自适应参数，并建立在线性能监测机制，当性能偏离基线

时，系统自动降级或切换；在持续验证评估阶段，新版本经过回归测试、试运行、批准、留档等阶段，并具备可回滚能力；在验证确认阶段，参考GB/T 42888对算法全生命周期与鲁棒性的要求，并参考GB/T 45654对更新评估与安全措施的规范，结合CCAR-145R4的持续质量管理、内部审核与记录保存的要求，实现“适用范围＋监控＋版本治理”。

d） 在运行监控阶段，业务使用者对关键结论实行强制双确认，由授权人员签署放行；当系统降级或关闭时，按传统方法进行诊断，将相关错误事件纳入再训练与规则修订的闭环管理，并纳入培训和考核；依据CCAR-145R4对放行责任不可转移以及人员资质和培训管理的硬性要求，参考GB/T 45654保障模型安全，提出关键结论多来源的必要性原则，确保人工智能仅作为受控的辅助工具来使用。

B.3 基础设施——养护：关键基础设施健康监测与诊断

B.3.1 场景描述

通过结合北斗厘米级定位数据、监测视频、传感器数据与人工智能模型，采集基础设施沉降、形变、裂缝、航道水深、流速流向、航标位置偏移等数据，实现道路、桥梁、隧道、边坡、航道、航标、通航建筑物、船闸等结构物的实时监测分析，实现风险预警。

B.3.2 风险分析

本场景宜重点考虑以下风险：

a） 不当输出：算法参数被恶意修改、传感器数据被篡改或伪造，导致监测结果失真，诊断输出错误；

b） 信息设施弹性弱：传感器或通信模块故障可能导致监测数据中断，导致系统不可用；预警服务可能因算力资源性能和数据处理延迟导致预警不及时。

B.3.3 防范措施

针对上述风险，宜采取以下防范措施。

a） 生产开发者、应用提供者在设计开发阶段加强基础安全建设与保护，对于模型参数等重要数据，采取强访问控制措施、加密存储使用和变更审批等措施；采用数字签名和区块链等技术，确保传感器数据不被篡改；结合卫星加密通信协议保障数据传输安全；设计部署多节点传感器网络，对关键通信链路实施如第五代移动通信技术（5G）＋卫星等双通道冗余设计。

b） 生产开发者、应用提供者在部署阶段采用容器化部署与资源配额管理，将预警服务与其他应用和服务隔离，确保关键功能拥有最低计算资源保障。

c） 生产开发者、应用提供者在运行监控阶段将关键数据实时备份。

d） 应用提供者在运行监控阶段限制访问速率，监控算力使用情况，当监测节点资源利用率异常时自动触发告警并切换至最近的备用节点，保证监测和预警服务不间断。

B.4 基础设施——规划建设：建筑信息模型辅助审核与应用增强

B.4.1 场景描述

基于建筑信息模型（BIM）技术实现设计合规性验证，并借助融合语音识别、语义识别等技术的多模态语义理解引擎，实现用户需求与知识库的实时匹配，支持设计方案的自动参数化生成，快速建模和自动审核，提升设计效率。

B.4.2 风险分析

本场景宜重点考虑以下风险：

a) 敏感数据泄露：用户需求与知识库匹配过程中可能涉及如图纸、参数等敏感设计数据的传输与存储，存在数据泄露风险；

b) 信息输出决策不可靠：多模态语义引擎可能因训练数据偏差或内容不当，推送不合规或低质量知识内容，或导致BIM模型生成错误。

B.4.3 防范措施

针对上述风险，宜采取以下防范措施。

a) 应用提供者在设计开发和部署阶段采用端到端加密传输，结合访问控制限制敏感数据访问；对知识库内容进行分级存储，如核心规范加密存储、普通案例开放访问等。

b) 数据提供者在设计开发阶段保证训练数据的多样性，避免训练数据偏差；应用提供者在设计开发阶段建立如设计参数、标注推荐依据等知识推送的可解释性机制，定期审查训练数据质量和多样性。

c) 应用提供者在设计开发阶段采取措施提升生成、审核等指令解析的准确性，并设置用户确认环节。

B.5 运输服务——货运物流：港航货物装卸智能排班与泊位分配调度

B.5.1 场景描述

在自动化码头作业中，基于时空图神经网络与深度时序预测模型，通过5G/光纤融合网络实时接入多源数据，实现船舶到港高精度预测、港航货物装卸智能排班与泊位分配调度。系统整合自动识别系统（AIS）轨迹数据、实时气象水文信息及历史作业记录，动态预测船舶精确到港时间，优化匹配泊位与岸桥资源，生成装卸与泊位调度最优方案，协同各业务系统联动，动态调整策略，保障船舶装卸、堆场存储与运输调度的无缝衔接。

B.5.2 风险分析

本场景宜重点考虑以下风险。

a) 数据投毒：训练数据可能被注入恶意样本或受到污染，导致模型预测出现系统性偏差，影响调度准确性，进而干扰港口作业计划与资源调配效率。

b) 供应链：开源库、硬件驱动等第三方组件可能被篡改或携带已知漏洞，成为系统攻击入口，威胁码头控制系统安全；API可能遭受拒绝服务攻击或恶意数据注入，导致服务中断或算法泄露，影响作业连续性。

c) 不当输出：系统输出的调度方案若存在逻辑缺陷或被恶意操控，可能导致船舶靠泊冲突、岸桥资源分配不均等问题，引发作业阻塞甚至安全事故。

B.5.3 防范措施

针对上述风险，宜采取以下防范措施。

a) 生产开发者、应用提供者、数据提供者在设计开发与部署阶段建立多层级数据验证机制，部署异常检测算法进行数据清洗，采用密码技术、数据脱敏或差分隐私等技术保护敏感数据，建立数据清洗规则与溯源机制，并建设操作校验与多级审批机制，防范输出错误。

b） 生产开发者与应用提供者在设计开发阶段构建安全可靠的设备管理体系，严格限定组件来源并实施动态检测；维护SBOM清单，遵循最小依赖原则，对高风险组件在部署与运行监控阶段实施隔离保护，定期评估组件安全性。

c） 生产开发者和应用提供者在运行监控阶段构建多层API防护体系，通过限流熔断、双重认证和应用防火墙进行防御；对敏感接口实施内容加密与数据脱敏，记录完整访问日志并开展审计分析，定期评估接口安全性；例如，对边缘计算节点采用国密证书认证，对调度API实施证书＋动态令牌等双因素认证。

d） 生产开发者在前期规划阶段考虑输出安全风险；在设计开发阶段构建噪声容忍度高的强鲁棒性方案，在验证确认阶段在港航生产环境中开展必要的安全测试与评估，保障系统输出准确可靠。

e） 应用提供者在运行监控阶段建立自动化监控平台，对系统运行状况进行实时监测与可疑行为告警；建立备份应急预案和故障切换机制，例如，当预测性能低于经验证设定的安全阈值或调度冲突次数超阈值时，自动切换至基于规则的传统调度系统；定期组织安全演练，持续优化系统参数。

B.6 运输服务——货运物流：航运航线动态优化与碳排放强度预测

B.6.1 场景描述

本场景旨在利用人工智能技术实现国际航运航线智能优化和碳排放强度预测。系统整合《国际海上人命安全公约》（SOLAS，[31]）及其修正案等国际航行规则和AIS轨迹、气象水文、泊位状态、燃油价格等动态多源数据，应用气象导航模型、能效模拟模型及碳强度指标计算引擎，经多目标优化算法处理，为船舶提供兼顾航行安全、经济效益与环保合规的航线规划及航速建议。

B.6.2 风险分析

本场景宜重点考虑以下风险。

a） 信息输出决策不可靠：模型可能产生幻觉，输出虚构的港口规定、错误的危险品积载方案或曲解海事公约条款，导致船舶面临合规风险或安全事故；面对地缘政治冲突、突发航道中断或极端异常天气等历史数据缺乏的“黑天鹅”事件，基于历史数据训练的模型可能失效或给出危险建议。

b） 数据投毒：气象数据、燃油价格等公开或第三方数据源可能遭遇数据投毒或供应链攻击，导致模型基于错误信息生成非最优或高风险航线（如误入恶劣天气区域），造成经济损失或排放超标等问题；恶意的全球定位系统/全球卫星导航系统（GPS/GNSS）干扰将导致模型收到错误的位置信息，可能会引导船舶偏离安全航道。

B.6.3 防范措施

针对上述风险，宜采取以下防范措施。

a） 生产开发者在前期规划阶段明确模型的设计运行域及适用边界；在验证阶段，利用仿真平台开展极端历史案例与对抗样本压力测试，评估模型在数据扰动下的鲁棒性。

b） 生产开发者设计多源数据融合校验机制，当单一来源数据与综合计算结果偏离度超过阈值时自动剔除；建立模型输出置信度评分机制，当评分低于安全阈值时，系统自动暂停服务并转为人工研判。

c） 生产开发者建立严格的数据准入规则，对第三方数据进行来源验证与异常检测；应用提供者保障模型具备可解释性，能够溯源推荐航线背后的法规依据与能效测算逻辑，定期审查训练数据的准确性与多样性。

d） 在运行监控阶段，应用提供者对关键输入参数（如油价、气象）进行实时监控，业务使用者建立

“人工智能辅助＋岸基专业人员决策”的人机协同机制。对于系统监测到的参数异常或低置信度建议，强制触发人工介入，由岸基管理人员或船长进行最终确认。

B.7 运输服务——货运物流：邮政物流智能运输

B.7.1 场景描述

通过摄像头、机器视觉估算、传感器、深度学习模型等，自动识别邮件快件的条形码、二维码、地址、尺寸、质量、形状、破损情况等信息，结合自动化控制实现邮件快件分拣；动态识别分拣负载瓶颈、自动规划机器人与人工协同作业节奏，提前分配配送任务，提高分拣效率，降低配送成本。

B.7.2 风险分析

本场景宜重点考虑以下风险：

a) 数据投毒：标注团队在对破损、皱褶、标签模糊等异常包裹进行分类时，若缺乏统一标准或质量复审流程，将产生噪声标签，使模型无法区分真实损伤与轻微瑕疵，影响分拣准确率和系统可信度；

b) 无限资源消耗：分拣调度算力资源可能被恶意占用或遭遇算力节点故障，会导致调度延迟或中断，分拣顺序无法及时更新，影响时效和系统运行。

B.7.3 防范措施

针对上述风险，宜采取以下防范措施。

a) 生产开发者、应用提供者在设计开发阶段制定标注规范和质量准入标准，明确“破损”“瑕疵”和“标签不清”等定义，并开展标注培训；引入双盲审核与一致性检查工具，对标注结果进行抽样复核与指标评估。

b) 应用提供者、数据提供者在运行监控阶段定期比对模型预测与人工审核结果，针对新增典型场景扩充标注集并持续迭代模型。

c) 生产开发者和应用提供者在设计开发和部署阶段对所有用户信息与路线数据在存储前进行加密，并仅在内网安全区域进行解密计算，部署细粒度访问控制与多因素认证，对用户数据的读取或导出等操作进行二次审批。

d) 应用提供者在运行监控阶段对数据访问和解密日志进行实时审计，同时对敏感字段进行动态脱敏处理，确保对外报告或分析结果仅含匿名化信息。

e) 生产开发者和应用提供者在设计开发阶段和部署阶段构建和部署白名单执行与代码签名验证，禁止非授权程序在调度服务器上运行并监控异常进程；通过容器化与资源配额管理保障最小算力供应正常。

f) 应用提供者在运行监控阶段建立实时监测和风险预警机制，实施算力使用监控与阈值告警，一旦检测到算力占用异常或推理延迟，立即启动备用切换节点并报告排查。

B.8 运输服务——出行服务：综合交通运输客流预测与组织优化

B.8.1 场景描述

预测节假日与突发情况客流高峰，融合铁路车次计划、民航航班计划、公路客运计划、城市轨道交通与公交计划、历史出行数据、安检通行耗时、旅客构成、天气、节假日及大型活动等多源数据，基于长短期记忆网络等时序模型来预测未来数小时各类出行方式及其安检通道的旅客吞吐量，结合流量监测，优化安检、候车厅/登机口、商业区动线、出行建议等安排，为旅客推荐最优行进路线和一体化出行路线，导航

调整实时提醒，实现资源动态增减、排队流程优化，兼顾通行效率与安全管控；同时为城市客运、公路、铁路、民航等的智能调度、行车组织优化等提供数据和决策支撑，为城内、城际一体化组合出行和绿色出行提供智慧支撑。

B.8.2 风险分析

本场景宜重点考虑以下风险：

a) 不当输出：早晚高峰、节假日客流高峰或光线和天气的变化，可能会使视觉算法难以准确分辨人头轮廓，出现低估客流、漏报拥堵预警，或因误报频繁触发分流指令，浪费人力并干扰旅客判断，降低系统的可用性和公信力，存在鲁棒性不强的风险；

b) 数据投毒：历史数据可能被篡改或注入异常样本，恶意攻击者可在数据采集或传输环节植入“虚假高峰”或“虚假低谷”记录，使模型学习到错误趋势，最终分配错误资源或生成错误路线。

B.8.3 防范措施

针对上述风险，宜采取以下防范措施。

a) 生产开发者和应用提供者在前期规划阶段明确验证要求和措施，设置人工监督机制；在设计开发阶段为监测模型接入多源数据融合机制，如发现单一来源数据与综合计算结果的偏离超过阈值时自动判定该输入为异常输入，并予以忽略；为预测模型设定置信度评分，当模型置信度低于阈值时自动暂停自动调度建议，转为人工或传统方式研判。

b) 应用提供者和业务使用者在运行监控阶段定期由值班调度员或安全员实地核对系统监测预警与现场客流情况，对所有未正确监测的典型场景进行记录，并结合现场情况分析，根据需要调整多源融合算法的权重分配和模型超参数设置，从而不断提升客流监测与预测的准确性和稳定性。

c) 生产开发者和应用提供者在设计开发阶段和部署阶段构建和部署数据源认证与哈希校验机制，对所有导入的历史数据进行完整性验证；引入时间序列异常检测算法，自动标记并剔除可疑样本。

d) 应用提供者、业务使用者在运行监控阶段对新入库数据进行监督，一旦发现数据分布异常，立即暂停模型更新并进行必要的人工审查。

B.9 运输服务——出行服务：航空运输智慧服务

B.9.1 场景描述

面向民航运输的客票销售、旅客服务、运行控制、空中管制等关键业务领域，利用关键词过滤、算法模型及人工筛选等技术对航班运行、机场运行、管制指令、旅客流量、天气预警等民航运营相关数据进行处理，构建训练语料库；基于自主可控的基座模型和算力资源进行微调训练，形成面向民航领域的大模型和智能体，提供机场资源智能分配、机组排班智能化、民航智能客服等服务，具体如下：

a) 机场资源智能分配：以机场实际运行为依托，基于多智能体协同决策平台，融合多源数据，通过强化学习算法动态优化廊桥分配、航空器滑行、地面服务资源调度、安检通道、值机柜台开启数量等资源分配方案；

b) 机组排班智能化：包括机组排班资料自动采集、数据智能处理、合规性自动校验、异常智能识别与自主优化调整，全面提升机组排班精细化和智能化管理水平；

c) 民航智能客服：包括智能交互与票务服务、行前与行中问询、个性化推荐与营销、机场资源查询等，深度融入航空公司对外服务与对内赋能体系。

B.9.2 风险分析

本场景宜重点考虑以下风险。

a) 提示词注入：用户可能向模型输入恶意或违法违规的诱导性问题，若模型安全防护不足，可能导致其生成不当内容，引发安全与合规风险。

b) 敏感数据泄露：人工智能系统在处理海量旅客个人信息、敏感语音、内部业务数据、机组人员隐私、资源配置详情等信息时，存在数据泄露与隐私侵犯风险。

c) 信息输出决策不可靠：由于分配算法对历史数据的依赖性较强，对极端天气、突发公共事件等异常场景适应性较弱，来源多样的机组排班数据不统一等，可能生成与实际脱节的资源分配方案或不准确的排班方案；或者因幻觉可能生成事实错误或具有误导性的回答，在民航此类高可靠性要求的领域，可能影响业务使用者的专业判断与决策，进而引发地面服务链条混乱等严重安全或运营后果。

d) 过度授权：高自主系统若遭受恶意攻击（如伪造航班延误数据），或智能调度的人工干预节点设置不合理，可能引发资源错配，造成机位闲置与拥堵并存，降低机场整体运行效率。

B.9.3 防范措施

针对上述风险，宜采取以下防范措施。

a) 业务使用者在前期规划阶段组织生产开发者、应用提供者开展系统的伦理安全与内容安全风险评估。

b) 生产开发者在设计开发阶段，明确训练数据的敏感信息排除清单、数据处理规则及语料库数据准入标准，建立标注人员的培训、考核与评级体系，实施标注人员的准入与退出机制；对数据进行预处理和清洗，建立完善的数据校验机制，保障数据安全合规；注入极端场景数据（如大面积航班备降）开展算法压力测试，建立动态阈值预警机制；对航班数据来源实施多方校验，规避单一数据源偏差；通过对抗训练、输入验证等技术手段，提升模型对对抗样本的防御能力；搭建私有化的训练平台和应用平台，确保敏感数据不出域，建立应用访问机制，确保核心信息仅在授权范围内流转；采用安全通信协议。

c) 应用提供者在部署阶段，部署有效的算法与完整的安全护栏体系，以防范价值观偏离风险，并对用户输入和模型输出进行审核与过滤。在运行监控阶段建立动态监测机制，及时发现并应对潜在注入和敏感数据泄露威胁，确保安全护栏机制持续有效、实时监测并定期优化，同时对输入信息进行记录与监控，支持审计追溯与异常行为分析；加强安全配置和访问控制，对于访问权限，按“最小必要”原则分级管控，明确留存访问日志天数。

d) 在运行监控阶段，业务使用者做好使用人员培训和知识库质量提升，如对客服座席进行人工智能安全素养和技能培训，涵盖大模型理论、技术、应用、安全、伦理等内容，提升客服人员的人工智能安全认知水平；智能客服回复内容的质量取决于知识库质量，客服专家定期对知识库内容进行更新，客服人员定时对人工智能回复的内容进行审核，不断完善智能客服系统的回复质量。

e) 生产开发者与应用提供者在前期规划阶段制定人工智能决策产生重大影响时的解释说明预案。在设计开发阶段，建立输出内容审核机制，构建民航各领域业务场景专用的提示词模板库与输出格式约束规范，确保内容输出安全可控。在部署阶段，搭建资源分配方案的A/B测试沙箱，新策略上线前经过48 h并行验证；设置资源调度“熔断规则”，当系统建议与塔台指令偏差超过15%时，自动触发人工接管流程。在运行监控阶段根据民航业务特点设置必要的人工复核与干预流程，并对大模型生成的关键内容进行来源核实与交叉验证，如机组排班智能体负责提供自动化的排班结果，业务使用者人工复核机组人员心理状态及跨基地协同等隐性风险，一旦出

现严重故障，可无缝切换到人工处理，双重保障机组排班业务正常运行。

f) 机场运行指挥中心等业务使用者在运行监控阶段，定期组织“人工智能—人工”协同处置演练，模拟突发故障下的权限切换流程；建立调度决策全流程追溯日志，确保人工智能建议的调整均有明确责任人员签字确认。

B.10 行业治理——政务服务：交通运输政务管理智能问答

B.10.1 场景描述

基于交通运输业务知识库，构建交通运输行业知识图谱与多轮问答模型，使用户能够以自然语言提问，系统可准确理解用户意图、智能检索法律法规、精确回答用户咨询和问题。支持政策法规解释、流程指引、业务办理辅助等多类问题类型。

B.10.2 风险分析

本场景宜重点考虑以下风险：

a) 信息输出决策不可靠：模型产生幻觉，生成看似合理的错误或误导性回答，如输出虚构的法条、流程或事件，影响政务权威性，可能带来法律责任和后果；

b) 敏感数据泄露：训练数据或问答中包含敏感政务信息，或用户通过问答系统获取到非公开的内部信息，存在数据泄露风险；

c) 提示词注入和不当输出：输入内容中包含高风险内容，包括用户原始输入、通过上下文关联之后构造的输入等；模型生成内容中包含高风险内容。相关风险要素见GB/T 45654—2025的附录A。

B.10.3 防范措施

针对上述风险，宜采取以下防范措施。

a) 生产开发者在设计开发阶段进行检查和复核，保障输出内容准确、合理。应用提供者在验证确认阶段对生产开发者提供的系统及相关说明进行测试和验证。

b) 生产开发者、应用提供者在设计开发阶段、运行监控阶段实现知识库的溯源与强制引用机制；生成的答案包含指向原始受控文件具体条款的精确链接或引用，如果生成内容无法在知识库中找到确切依据，则标记为“低置信度”或拒绝回答，以抑制幻觉。

c) 生产开发者在设计开发阶段对训练数据进行脱敏处理和访问分级管理，加强模型对抗攻击防御能力，开展对抗攻击测试。

d) 应用提供者在运行监控阶段加强数据安全防护，对输入输出内容进行检查和权限控制，并在必要时采取人工复核，引入知识库更新机制，确保法律法规、政策等信息的及时准确性，必要时进行重新训练和模型更新；对用户输入进行敏感词匹配和语义合规检测，识别风险提问，并进行拦截，输出预设置的拒答回复；在内容生成时能够自动识别生成内容中可能涉及的风险要素，对高风险内容进行拦截过滤；对多次违规输入的高风险用户采取标记行为、暂停提问、封停账户等措施；在退役下线阶段进行各类数据的安全处置。

e) 业务使用者在运行监控阶段定期检查系统输入输出，及时向生产开发者、应用提供者反馈安全风险相关信息。

B.11 行业治理——运行监测：公路交通运行监测与分析研判

B.11.1 场景描述

依托大模型时空推理引擎，融合视频数据、交通流监测数据、气象数据、收费数据等多要素动静态时

空数据，基于人工智能算法，实现公路交通网车流动态预测、交通事件主动发现，提升路网运行研判精准度，支持拥堵推演、事故溯源及恶劣天气影响评估，支持自主式决策调度和快速应急处置。

B.11.2 风险分析

本场景宜重点考虑以下风险：

a) 信息输出决策不可靠：人工智能预测不准确导致路网交通拥堵或服务紊乱，存在经济社会运行安全风险；

b) 提示词注入：攻击者通过创建精心设计的对抗样本数据，恶意输入干扰模型预测，存在外部对抗攻击风险。

B.11.3 防范措施

针对上述风险，宜采取以下防范措施。

a) 生产开发者在前期规划阶段和设计开发阶段进行有效性验证并建立误差容忍机制与人工预警补偿机制；在设计开发阶段加强数据输入校验与模型防御机制，通过主动生成并在训练数据中注入对抗数据等方式进行对抗训练。

b) 应用提供者在运行监控阶段对模型进行安全监测和输入输出过滤；对模型准确性进行核实，并采取必要的人工补偿措施、定期开展安全演练。

c) 业务使用者在运行监控阶段定期检查系统输入输出，及时向生产开发者、应用提供者反馈安全风险相关信息。

参 考 文 献

[1] GB 20263 导航电子地图安全处理技术基本要求

[2] GB/T 22239 信息安全技术 网络安全等级保护基本要求

[3] GB/T 22240 信息安全技术 网络安全等级保护定级指南

[4] GB/T 35273 信息安全技术 个人信息安全规范

[5] GB/T 39204 信息安全技术 关键信息基础设施安全保护要求

[6] GB/T 39786 信息安全技术 信息系统密码应用基本要求

[7] GB/T 41479 信息安全技术 网络数据处理安全要求

[8] GB/T 42755—2023 人工智能 面向机器学习的数据标注规程

[9] GB/T 42888—2023 信息安全技术 机器学习算法安全评估规范

[10] GB/T 43207 信息安全技术 信息系统密码应用设计指南

[11] GB/T 43697 数据安全技术 数据分类分级规则

[12] GB/T 43698 网络安全技术 软件供应链安全要求

[13] GB/T 45288.1—2025 人工智能 大模型 第1部分:通用要求

[14] GB/T 45288.2—2025 人工智能 大模型 第2部分:评测指标与方法

[15] GB/T 45288.3—2025 人工智能 大模型 第3部分:服务能力成熟度评估

[16] GB/T 45392—2025 数据安全技术 基于个人信息的自动化决策安全要求

[17] GB/T 45574 数据安全技术 敏感个人信息处理安全要求

[18] GB/T 45652 网络安全技术 生成式人工智能预训练和优化训练数据安全规范

[19] GB/T 45654—2025 网络安全技术 生成式人工智能服务安全基本要求

[20] GB/T 45674 网络安全技术 生成式人工智能数据标注安全规范

[21] GB/T 45958 网络安全技术 人工智能计算平台安全框架

[22] JT/T 904 交通运输行业网络安全等级保护定级指南

[23] JT/T 1417 交通运输行业网络安全等级保护基本要求

[24] JT/T 1522 交通运输数据安全分级和保护要求

[25] CCAR-145R4 民用航空器维修单位合格审定规则

[26] ISO/IEC 5339:2024 Information technology—Artificial intelligence—Guidance for AI applications

[27] ISO/IEC 22989:2022 Information technology—Artificial intelligence—Artificial intelligence concepts and terminology

[28] ISO/IEC TR 29119-11:2020 Software and systems engineering—Software testing—Part 11: Guidelines on the testing of AI-based systems

[29] ISO/IEC 42001:2023 Information technology—Artificial intelligence—Management system

[30] ISO/IEC 42005:2025 Information technology—Artificial intelligence (AI)—AI system impact assessment

[31] International Maritime Organization International Convention for the Safety of Life at Sea (SOLAS) 1974

[32] TC260-004 政务大模型应用安全规范

[33] TC260-PG-20211A 网络安全标准实践指南 人工智能伦理安全风险防范指引

[34] TC609-5-2025-03 高质量数据集 分类指南

［35］ 全球人工智能治理倡议(国家互联网信息办公室,2023年10月)

［36］ 人工智能安全治理框架2.0(全国网络安全标准化技术委员会、国家计算机网络应急技术处理协调中心,2025年9月)政务领域人工智能大模型部署应用指引(中央网络安全和信息化委员会办公室、国家发展和改革委员会,2025年10月)

［37］ 高质量数据集建设指引(中国信息通信研究院等, 2025年8月)

［38］ 人工智能伦理治理标准化指南(2023版)(国家人工智能标准化总体组、全国信标委人工智能分委会, 2023年3月)

［39］ 智能网联汽车“车路云一体化”规模建设与应用参考指南(1.0版)(国家智能网联汽车创新中心等,2024年5月)

［40］ OWASP Top 10 for LLM Applications 2025

［41］ OWASP Top 10 for Agentic Application 2026

［42］ WDTA AI-STR-01 Generative AI Application Security Testing and Validation Standard

［43］ WDTA AI-STR-04 Single AI Agent Runtime Security Testing Standards